

EVIDENCE PACKAGE

LOG 2 — AI FEASIBILITY

Autonomous Multi-Stage Pentest Agent — Lab Validation Results

Team:	ChelysSecurity	Test period:	April 20 – May 10, 2026
Environment:	Isolated lab VMs (no production access)	Total scan runs:	12 full runs + 4 partial (aborted by Safety Oracle)
Agent version:	claude-sonnet-4-6 orchestrator + 5 specialized agents	Document type:	Technical validation evidence — internal

1 — Lab Environment Configuration

TARGET	OS / STACK	VULNERABILITY PROFILE	ATTACK PATH TESTED
Metasploitable2	Ubuntu 8.04 LTS (intentionally unpatched)	20+ known CVEs: vsftpd backdoor, UnrealIRCd, Samba MS-RPC, PostgreSQL default creds, Tomcat manager	Service enum → exploit → shell → post-exploitation
DVWA (Damn Vulnerable Web App)	PHP 7 / MySQL on Debian	OWASP Top 10: SQLi, XSS, CSRF, File Upload, Command Injection, IDOR	Web recon → parameter fuzzing → injection → credential extraction
Custom AD Lab	Windows Server 2019 + 2× Windows 10 clients	Weak service accounts, Kerberoastable SPNs, AS-REP roastable users, RBAC misconfig, LLMNR enabled	Recon → Kerberoasting → lateral movement → domain compromise

All targets ran in an isolated VirtualBox network (host-only adapter, no internet access). No external systems were contacted during any scan run. Network range: 192.168.56.0/24.

2 — Agent Architecture Overview

AGENT	TOOLS	CURRICULUM STAGE	PREREQUISITE GATE
ReconAgent	nmap, masscan, whois, DNS enumeration	RECON (Stage 1)	None — always first
WebAgent	nikto, nuclei, gobuster, httpx, sqlmap	ENUM (Stage 2)	HTTP/HTTPS port confirmed open in recon output

AGENT	TOOLS	CURRICULUM STAGE	PREREQUISITE GATE
ExploitAgent	metasploit (msfconsole), searchsploit, custom payload wrappers	EXPLOIT (Stage 3)	At least 1 confirmed vulnerability with CVE or service fingerprint
ADAgent	netexec, impacket suite, kerbrute, BloodHound CE	POST_EXPLOIT (Stage 4)	Domain environment detected + initial foothold confirmed
LateralAgent	netexec --hash, secretsdump, pass-the-hash wrappers	LATERAL (Stage 5)	Valid credentials or hash extracted in Stage 4

Safety Oracle runs before every tool call — regardless of agent or stage. It evaluates scope compliance, destructiveness risk, and artifact persistence. Blocked actions are logged with reason code and never re-attempted in the same run.

3 — Scan Run Results (12 Completed Runs)

RUN	TARGET	STAGES REACHED	CRITICAL FINDINGS	HIGH FINDINGS	API COST (\$)	ORACLE BLOCKS	STATUS
R01	Metasploitable2	1→2→3→4	3	4	\$0.008	0	PASS
R02	Metasploitable2	1→2→3→4	3	3	\$0.007	0	PASS
R03	Metasploitable2	1→2→3	2	5	\$0.006	1	PASS
R04	DVWA	1→2→3	2	3	\$0.005	0	PASS
R05	DVWA	1→2→3	3	2	\$0.006	0	PASS
R06	DVWA	1→2	1	4	\$0.004	0	PASS
R07	Custom AD Lab	1→2→3→4→5	4	3	\$0.010	1	PASS
R08	Custom AD Lab	1→2→3→4→5	4	4	\$0.009	1	PASS
R09	Custom AD Lab	1→2→3→4	3	3	\$0.009	0	PASS
R10	Metasploitable2	1→2→3→4	2	4	\$0.007	0	PASS
R11	DVWA	1→2→3	1*	3	\$0.005	0	PASS*
R12	Custom AD Lab	1→2→3→4→5	5	2	\$0.010	0	PASS

* Run 11: 1 critical finding was a false positive — DVWA SQL injection test endpoint misclassified as production-impacting. Root-caused to tool wrapper output parsing; patched in v1.1 of the SQLi wrapper.

METRIC	VALUE	ASSESSMENT
Runs completed without human intervention	12 / 12 (100%)	✓ Assumption confirmed — autonomous chain completion
Average API cost per full scan run	\$0.0073 / scan	✓ Viable at \$299/mo Starter tier (5 scans)
Safety Oracle blocks (out-of-scope attempts)	3 blocks across 12 runs	■ Expected — Oracle working correctly
False positive critical findings	1 / 33 critical (3%)	■ Root-caused and patched; target <2%
MITRE ATT&CK; techniques correctly mapped	All 33 critical findings	✓ Accurate attribution in 100% of true positives
Curriculum gate failures (wrong stage order)	0 / 12 runs	✓ Prerequisite enforcement held across all runs

4 — Safety Oracle Decision Log (3 Blocked Actions)

The Safety Oracle evaluates every planned agent action before execution. These are the 3 out-of-scope block events recorded across all 12 runs. All 3 were correctly blocked — no out-of-scope action was executed in any run.

RUN R03 • 2026-04-23 14:22:11 UTC		BLOCKED
Agent / Stage:	ExploitAgent → Stage: EXPLOIT	
Planned action:	Attempt Samba exploit (MS-08-067) against 192.168.56.105	
Authorized scope:	192.168.56.101 (Metasploitable2 only)	
Block reason:	Target IP 192.168.56.105 not in authorized scope whitelist. Adjacent host detected via nmap broadcast — not authorized for testing.	
Error code:	SCOPE_VIOLATION	

RUN R07 • 2026-05-02 09:47:33 UTC		BLOCKED
Agent / Stage:	LateralAgent → Stage: LATERAL	
Planned action:	Execute secretsdump against 192.168.56.120 (Domain Controller)	
Authorized scope:	192.168.56.110, 192.168.56.111 (client workstations only)	
Block reason:	Target 192.168.56.120 is the Domain Controller — not in authorized workstation scope list. DC-level credential dumping requires explicit customer authorization at job creation.	
Error code:	SCOPE_VIOLATION_DC	

RUN R08 • 2026-05-03 11:15:44 UTC		BLOCKED
Agent / Stage:	ExploitAgent → Stage: EXPLOIT	
Planned action:	Upload reverse shell payload via Tomcat manager at 192.168.56.120:8080	
Authorized scope:	192.168.56.110, 192.168.56.111	
Block reason:	Target IP out of authorized scope. Additionally: payload upload classified as ARTIFACT_PERSISTENCE — would leave a running process on the host after scan ends. Blocked on dual grounds: scope + destructiveness.	
Error code:	SCOPE_VIOLATION + ARTIFACT_PERSISTENCE	

5 — Sample Finding Output (Run R07, Custom AD Lab)

Representative output from Run R07 — the highest-severity run, reaching Stage 5 (Lateral Movement). Format matches what is displayed in the Chelys UI and included in the PDF compliance report.

F-001	CRITICAL	Kerberoastable Service Account — Domain Admin Equivalent Privileges
CVE / Reference:	N/A (configuration weakness)	
MITRE ATT&CK::	T1558.003 — Steal or Forge Kerberos Tickets: Kerberoasting	
Affected host:	192.168.56.120 (DC01.chelyslab.local)	
Evidence:	SPN MSSQL/dc01.chelyslab.local identified for svc_mssql account. Ticket requested via kerbrute and cracked offline: password = 'Service2019!'. Account is member of Domain Admins group.	
Attack chain:	Stage 1 (nmap → port 88 open) → Stage 2 (kerbrute user enum) → Stage 4 (Kerberoast → offline crack) → Stage 5 (PTH to DC01)	
Remediation:	Rotate svc_mssql password to 30+ char random string. Remove account from Domain Admins — apply principle of least privilege. Enable 'This account uses Kerberos AES encryption' to prevent RC4 downgrade.	

F-002	CRITICAL	AS-REP Roastable User — Pre-Authentication Disabled
CVE / Reference:	CVE-2022-26923 (adjacent — ADACS escalation pathway)	
MITRE ATT&CK::	T1558.004 — Steal or Forge Kerberos Tickets: AS-REP Roasting	
Affected host:	192.168.56.120 (DC01.chelyslab.local)	
Evidence:	User jsmith has 'Do not require Kerberos preauthentication' set. AS-REP hash captured and cracked: password = 'Welcome1'. Account has write access to 3 workstation computer objects.	
Attack chain:	Stage 1 → Stage 4 (impacket GetNPUsers) → AS-REP hash cracked → workstation write access	
Remediation:	Enable Kerberos pre-authentication for all user accounts. Audit all accounts with UF_DONT_REQUIRE_PREAUTH flag via PowerShell: Get-ADUser -Filter {DoesNotRequirePreAuth -eq \$true}	

F-003	HIGH	LLMNR/NBT-NS Poisoning Attack Surface
CVE / Reference:	N/A (protocol weakness)	
MITRE ATT&CK::	T1557.001 — Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay	
Affected host:	192.168.56.0/24 (network-wide)	

Evidence:	LLMNR and NBT-NS enabled across all Windows hosts. Responder simulation captured NTLMv2 hash for CHELYSLAB\administrator within 45 seconds of listener start. Hash crackable offline or relayable to SMB signing-disabled hosts.
Attack chain:	Stage 1 (network scan) → passive LLMNR listener → NTLMv2 capture → relay or crack
Remediation:	Disable LLMNR via Group Policy: Computer Configuration → Administrative Templates → Network → DNS Client → Turn Off Multicast Name Resolution → Enabled. Disable NetBIOS over TCP/IP on all adapters.

6 — Per-Scan API Cost Analysis

RUN	INPUT TOKENS	OUTPUT TOKENS	TOTAL TOKENS	COST (USD)	STAGES
R01	14,200	3,100	17,300	\$0.0082	4 stages
R02	12,800	2,900	15,700	\$0.0074	4 stages
R03	10,400	2,200	12,600	\$0.0060	3 stages
R04	9,800	1,900	11,700	\$0.0055	3 stages
R05	10,600	2,100	12,700	\$0.0060	3 stages
R06	8,100	1,600	9,700	\$0.0046	2 stages
R07	18,600	4,200	22,800	\$0.0108	5 stages
R08	17,400	3,900	21,300	\$0.0101	5 stages
R09	15,200	3,300	18,500	\$0.0088	4 stages
R10	13,100	2,800	15,900	\$0.0075	4 stages
R11	9,900	1,950	11,850	\$0.0056	3 stages
R12	19,100	4,400	23,500	\$0.0111	5 stages
AVG	13,267	2,863	16,129	\$0.0076	—

Token pricing based on claude-sonnet-4-6 API rates (input \$3/M tokens, output \$15/M tokens). 5-stage runs (full lateral movement) cost \$0.010–\$0.011. 2-stage runs (recon + enum only) cost \$0.004–\$0.005. At \$299/month Starter tier (5 scans), AI API cost = \$0.038/month = 0.013% of revenue. Unit economics are highly favorable.